

FIAP

Turma 1AIE

NABBA

AI Engineering & Multi-Agents

Governance & Responsible AI

Parte 4 ✓

 /sergiomantovani

@ /profsergio.mantovani@fiap.com.br

Quem sou eu?



Sergio Mantovani

- 48 anos, casado, pai de uma menina de 13 anos

Hobbies principais:



Resumo profissional:

- Diretor associado de AI & Data na Accenture, líder da prática de “Responsible AI” para América Latina
- +25 anos de experiência, focado em soluções de Dados e IA, e passagens por empresas multinacionais de diversos ramos, como bens de consumo, farmacêutico, telecom, seguros e financeiro, recursos naturais, tendo exercido papéis de liderança regional América Latina e Global.
- Graduado em Análise de Sistemas, e pós-graduado em Administração e em Gestão de Projetos, além de diversos cursos e certificações técnicas e de gestão, incluindo “Responsible AI” na Universidade de Stanford/USA.
- Coautor do “Guia de IA para Conselheiros de Administração” lançado em Out/2024 (Accenture, Microsoft e IBGC).
- Professor no MBA de Data Science & IA e no MBA AI Engineering & Multi-Agents da FIAP

Contatos:



/sergiomantovani



@profsergio.mantovani@fiap.com.br

Principais empresas:

accenture

Porto

BUNGE

Mondelēz
International

Roche

natura

Expertise:

- Responsible AI
- Data & AI Strategy
- Data & AI Governance
- Data Architecture
- Data Engineering
- Data Analytics
- Project Mngmt & Agile Methods

Agenda de Aulas

Turma: 1AIE

Junho 2026						
D	S	T	Q	Q	S	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30				

Julho 2026						
D	S	T	Q	Q	S	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30	31	

Agenda da disciplina

Temas das 5 aulas - Turma 1AIE

Temas que vamos cobrir

1	Governança e Gestão de Dados
2	Riscos da IA e Princípios de IA Responsável
3	Governança, Frameworks e Regulação
4	Mitigação de Riscos da IA
5	Considerações para Agentic AI e Projeto Final

O PAPEL DO AI ENGINEER

Você não é só técnico.

Você é responsável por:

Decisões automatizadas

que afetam pessoas reais

Impacto em pessoas

clientes, funcionários, sociedade

Risco organizacional

regulatório, financeiro, reputacional

Considerações Importantes

- Procure ser pontual – As aulas iniciam-se às 19h e terminam às 23h
 - Chamadas são liberadas às 19:15h e 22:40h
- Se possível, silencie seu celular e os demais canais de comunicação. Desconecte-se!
- Será ótimo se você puder ligar sua câmera!!
- Participe das aulas
 - Pergunte. Este é o momento!
 - Compartilhe exemplos da sua experiência profissional, pessoal ou de algo que você leu
 - Traga novos assuntos ligados à disciplina
 - Seu feedback é precioso
- Faça as atividades sugeridas em sala de aula
- Apesar de virtual, sua participação deve ser real

Onde estamos na disciplina

5 partes, perspectivas complementares

01

Governança & Gestão de Dados

DAMA, qualidade, ciclo de vida, metadados, produto de dados

02

Riscos da IA & Princípios de IA Responsável

Taxonomia de riscos · princípios de IA Responsável · Estudo de Casos

03

Governança, Frameworks e Regulação

Melhores Práticas em Governança de IA · NIST AI RMF · ISO 42001 · EU AI Act · LGPD · PL 2338

04

Mitigação de Riscos da IA

Justiça · robustez · XAI · privacidade · segurança · guardrails

05

Agentic AI & Projeto Final

Agentes autônomos, riscos amplificados · Quantum Commerce

VOCÊ ESTÁ AQUI



GOVERNANCE &
RESPONSIBLE AI

P A R T E 0 4

Mitigação de Riscos da IA

Os pilares e suas ferramentas práticas

AI Engineering & Multi-Agents · Turma 1A1ER



A Lógica da Mitigação de Riscos de IA

Mitigar não é eliminar o risco, é reduzir a probabilidade e o impacto a um nível aceitável para a organização e para as pessoas afetadas. Toda mitigação envolve trade-offs.

Evitar

Não desenvolver ou desativar o caso de uso. Quando o risco é inaceitável e nenhuma mitigação o torna tolerável.

Reduzir

Implementar controles técnicos e processuais que diminuem a probabilidade ou o impacto do risco.

Transferir

Compartilhar o risco com terceiros via seguros, contratos ou parcerias, sem transferir a responsabilidade.

Aceitar

Tomar decisão consciente de conviver com o risco residual, documentada e aprovada pela liderança.

QUANDO MITIGAR? Por fase do ciclo de vida

Concepção

Análise de risco · Política de uso aceitável · DPIA

Dados

Auditoria de viés · Consentimento · Minimização · Linhagem

Desenvolvimento

Fairness testing · Adversarial testing · Model card · SHAP

Deploy

Testes de segurança · Red team · Thresholds de alerta · HITL

Operação

Drift detection · Auditoria · Incidentes · Revisão periódica

Pilares de Responsible AI

Cada pilar = um conjunto de riscos + um conjunto de controles



1 Justiça e Inclusão

Vieses e discriminação



2 Confiabilidade & Robustez

Acurácia, alucinações, drift



3 Transparência & Explicabilidade

Como e por que o modelo decidiu



4 Responsabilidade c/ Humanos no Loop

Supervisão e responsabilização



5 Privacidade & Gestão de Dados

PII, LGPD/GDPR, dados sintéticos



6 Segurança

Ataques adversariais, prompt inj.

Ferramentas-chave que veremos: Fairlearn, AIF360, SHAP, LIME, Captum, Microsoft Presidio, NeMo Guardrails, Llama Guard, Guardrails AI, MITRE ATLAS, OWASP LLM Top 10.

Justiça em IA não é só 'paridade demográfica'. Segundo o NIST SP 1270, viés tem três naturezas distintas, e mitigação requer abordagens diferentes para cada uma.

1

Sistêmico

ONDE OCORRE

Sociedade, instituições, processos de negócio

CAUSA PRINCIPAL

Estruturas sociais, culturais ou políticas desiguais que se refletem nos dados e decisões

Ex.: histórico de crédito que penaliza CEPs de comunidades periféricas

2

Computacional / Estatístico

ONDE OCORRE

No dataset e no algoritmo

CAUSA PRINCIPAL

Erros de amostragem, baixa representatividade ou formulação matemática inadequada

Ex.: dataset de imagens com 90% de tons de pele claros

3

Cognitivo-Humano

ONDE OCORRE

Na interpretação e uso dos resultados

CAUSA PRINCIPAL

Falhas psicológicas dos humanos ao usar a IA: viés de confirmação, ancoragem, automação

Ex.: médico aceita diagnóstico do modelo sem questionar

⚠ RISCO PRINCIPAL: Discriminação algorítmica sistemática de grupos protegidos. Invisível, escalável e juridicamente responsabilizável.

Auditoria de viés nos dados

Analisar distribuição demográfica no dataset de treinamento. Verificar representatividade e taxas de erro por grupo.

Fairness constraints no modelo

Aplicar restrições de equidade durante o treinamento: demographic parity, equalized odds, calibration. Trade-off explícito com acurácia agregada.

Testes de paridade pós-treino

Medir métricas de fairness nos dados de teste antes do deploy. Definir thresholds aceitáveis por grupo. Documentar no model card.

Monitoramento contínuo por grupo

Monitorar performance em produção. Alertar quando disparidade entre grupos superar threshold. Retreinar se necessário.



FERRAMENTAS

Fairlearn (Microsoft) · IBM AI Fairness 360 · Google What-If Tool · Aequitas (UChicago)



TRADE-OFF

Fairness ↔ Acurácia: equilibrar taxas de erro entre grupos pode reduzir a performance agregada do modelo.

Pré-processamento

Antes do treino — agir nos DADOS

- Reweighting (IBM AIF360): dar mais peso a amostras subrepresentadas
- Disparate Impact Remover: ajustar features sem mudar rótulos
- Data augmentation balanceada / sampling estratificado
- Geração de dados sintéticos para classes minoritárias

In-processing

Durante o treino — agir no MODELO

- Adversarial Debiasing: rede adversária penaliza previsibilidade do atributo sensível
- ExponentiatedGradient / GridSearch (Fairlearn): otimização com restrição de fairness
- Prejudice Remover Regularizer (loss customizada)
- Fair Representations (mapeamento para espaço justo)

Pós-processamento

Após o treino — agir nas SAÍDAS

- ThresholdOptimizer (Fairlearn): thresholds diferentes por grupo
- Calibrated Equalized Odds (AIF360): calibrar e ajustar odds
- Reject Option Classification: revisar previsões em zona de incerteza
- Auditoria humana / HITL nas decisões de fronteira

Ferramenta	Mantenedor	Pontos fortes	Pontos de atenção	Quando usar
Fairlearn	Microsoft / Comunidade	API limpa (sklearn-like); dashboard interativo; classe + regressão; mitigação in-processing e post-processing	Foco em fairness por subgrupo; menos mitigadores pré-proc.	Times com stack scikit-learn / Azure ML
AI Fairness 360 (AIF360)	IBM	≈ 70 métricas e 10+ algoritmos de mitigação (pre/in/post); integrado a Watson	Curva de aprendizado mais íngreme; documentação densa	Pesquisa, auditoria regulatória, casos com restrições legais
What-If Tool	Google / PAIR	Visualização 'what-if' para Jupyter/TensorBoard sem código	Não tem mitigadores; só análise	Workshop, exploração com stakeholders não-técnicos
Aequitas	U. Chicago	Foco em audit/relatórios para policymakers; bias report COMPAS-style	Não inclui mitigadores	Compliance / due-diligence regulatória
SageMaker Clarify	AWS	Pré-treino + pós-treino + explicabilidade SHAP; integrado ao SageMaker Pipelines	Lock-in AWS; pago por uso	Times já em SageMaker que querem governance integrada

⚠ RISCO PRINCIPAL: Sistema falha silenciosamente em condições reais: entradas fora da distribuição, mudanças de contexto ou ataques adversariais.

Testes fora da distribuição (OOD)

Testar o modelo com inputs que diferem do dataset de treino: idiomas, dialetos, formatos, casos extremos. Medir degradação de performance.

Adversarial robustness testing

Gerar exemplos adversariais deliberadamente para enganar o modelo. Avaliar resistência. Implementar adversarial training se necessário.

Incerteza calibrada (confidence)

Garantir que o modelo saiba quando não sabe: calibrar scores de confiança. Sinalizar incerteza ao usuário em vez de responder com falsa segurança.

Mecanismos de fallback

Definir o que o sistema faz quando detecta baixa confiança: rota para humano, resposta conservadora ou recusa explícita. Nunca falha silenciosa.

FERRAMENTAS

Evidently AI · DeepChecks · Alibi Detect (SeldonIO) · MLflow Model Registry

TRADE-OFF

Robustez ↔ Performance: modelos mais conservadores e com fallback tendem a ser mais lentos ou ter menor acurácia em casos limite.

Confiabilidade

ACURÁCIA + CONSISTÊNCIA

Capacidade do sistema funcionar conforme esperado, sem falhas, durante toda a vida útil sob as condições de uso previstas.

Robustez

RESILIÊNCIA

Capacidade do sistema manter desempenho aceitável em entradas fora da distribuição de treino, ruído, ataques adversariais e drift.

Métricas de qualidade: exemplos por tipo de modelo

Tipo	Métrica	O que mede
Regressão	MAE / RMSE	Erro médio absoluto / quadrático
Regressão	R²	Variância explicada
Regressão	MAPE	Erro % (escala interpretável)
Classificação	Precision / Recall	Acertos positivos / cobertura
Classificação	F1-score	Harmônica de P e R
Classificação	ROC-AUC	Capacidade de ranqueamento
LLM / GenAI	BLEU / ROUGE	Similaridade com referência
LLM / GenAI	Hallucination Rate	Taxa de afirmações não suportadas
LLM / GenAI	Faithfulness (RAGAS)	Alinhamento da resposta com contexto
LLM / GenAI	BERTScore / G-Eval	Avaliação semântica via LLM-judge

Alucinação = saída plausível mas factualmente incorreta ou não suportada. É a falha de robustez nº 1 em LLMs e a maior barreira para adoção em domínios críticos.

Tipos comuns

Factual

Afirma fatos errados (datas, nomes, valores).

“A capital da Austrália é Sidney.”

Faithfulness

Resposta não suportada pelo contexto/fonte.

RAG cita um documento que não diz aquilo.

Lógica/raciocínio

Conclui errado mesmo com fatos certos.

Soma de juros mensais errada apesar de ter os números.

Mitigações práticas

- ✓ **RAG (Retrieval-Augmented Generation)**
Aterre as respostas em fontes confiáveis indexadas c/ bases vetoriais (ex.: Pinecone, Weaviate, OpenSearch).
- ✓ **Citação obrigatória**
System prompt exige citação literal e bloqueio de resposta sem fonte.
- ✓ **Self-consistency / chain-of-verification**
Modelo se auto-verifica gerando perguntas de checagem (Dhuliawala 2023).
- ✓ **Validação programática**
Schemas com Pydantic/Guardrails AI; regex e checagens factuais.
- ✓ **LLM-as-a-judge (RAGAS, G-Eval)**
Avalia faithfulness em pipeline contínuo (CI/CD para LLMs).
- ✓ **Disclaimers e confidence scores**
Comunicar incerteza ao usuário final (ex.: 'Verifique sempre').

Red Team:

grupo autorizado e organizado para emular ataques adversários contra a postura de segurança de um sistema. Para IA, simula prompt injection, jailbreak, extração de dados, geração de conteúdo nocivo, viés, etc.

Como estruturar

- Definir escopo e taxonomia de risco (NIST/MITRE ATLAS)
- Time interno + externo (caça-vulnerabilidade)
- Ataques por categoria: Safety, Security, Privacy, Bias
- Documentar prompts e respostas para reprodução
- Loop com Blue Team e ciclo de remediação

Ferramentas

- PyRIT (Microsoft) — automação de red-team para GenAI
- Garak (NVIDIA) — scanner de vulnerabilidades em LLM
- DeepTeam — framework com OWASP LLM Top 10 nativo
- Promptfoo — testes adversariais em CI/CD
- Lakera Red — plataforma comercial de red-teaming

Categorias de ataque

- Jailbreak (DAN, role-play, encoding)
- Prompt Injection (direta e indireta)
- Data exfiltration (system-prompt leak)
- Toxic/biased generation
- Hallucination triggers
- Resource exhaustion (DoS)

Os termos são frequentemente usados como sinônimos, mas atendem a perguntas diferentes — e exigem mecanismos diferentes para serem implementados.

Transparência

“O QUE é o sistema?”

Grau em que informações relevantes sobre o sistema estão disponíveis, acessíveis e compreensíveis para todas as partes interessadas.

- Documentação dos dados (origem, qualidade, representatividade)
- Detalhes do modelo (arquitetura, parâmetros, fornecedor)
- Metodologia de avaliação (testes, métricas, auditorias)
- Limitações conhecidas e cenários de mau funcionamento
- Aviso ("disclaimer") de uso de IA, especialmente em GenAI

Artefato típico: Model Card · Data Sheet · System Card · AI Fact Sheet

Explicabilidade (XAI)

“POR QUE essa decisão?”

Capacidade do sistema de fornecer motivos compreensíveis para suas previsões ou decisões individuais — adaptados ao público-alvo.

- Explicação local: por que ESTA previsão? (LIME, SHAP local)
- Explicação global: como o modelo decide em geral? (SHAP summary)
- Visual: Grad-CAM, saliency maps (visão computacional)
- Atenção: attention weights (transformers / NLP)
- Counterfactuals: "o que mudaria se X fosse diferente?"

Exemplo: "crédito recusado por histórico de inadimplência (peso 0.42) e renda baixa (peso 0.31)"

⚠ RISCO PRINCIPAL: Decisões automatizadas sem explicação impedem auditoria, contestação e responsabilização — e violam LGPD Art. 20 e EU AI Act.

SHAP (SHapley Additive Explanations)

Atribui a cada feature a sua contribuição marginal para a predição. Funciona com qualquer modelo (pós-hoc, model-agnostic). Padrão de mercado.

LIME (Local Interpretable Model-Agnostic)

Gera uma aproximação local linear do modelo para explicar previsões individuais. Útil para textos, imagens e dados tabulares.

Model Cards e Datasheets

Documentar: objetivo do modelo, dados de treino, métricas por grupo, limitações conhecidas e uso adequado. Padrão Google/HuggingFace.

Logging de decisões automatizadas

Registrar inputs, outputs e features relevantes de cada decisão. Garantir rastreabilidade para auditoria e contestação. Obrigatório para alto risco.



FERRAMENTAS

SHAP (Python) · LIME · InterpretML (Microsoft) · Alibi Explain



TRADE-OFF

Explicabilidade ↔ Performance: modelos intrinsecamente interpretáveis (árvores, regressão) têm menor acurácia que deep learning.

Ferramenta	Mantenedor	Pontos fortes	Pontos de atenção	Quando usar
SHAP	Slundberg / OSS	Padrão de mercado; suporte a árvores, DL, kernels; visualizações ricas	Custo computacional alto fora de TreeSHAP; assume independência de features	Modelos tabulares em produção; auditorias; compliance
LIME	Marco Ribeiro / OSS	Rápido (~85ms); model-agnostic; intuitivo para stakeholders	Instável (resultados variam entre runs); só local	Explicações ad-hoc; latência baixa; arquiteturas exóticas
Captum	Meta (PyTorch)	Suite completa para PyTorch (IG, DeepLift, Grad-CAM, LRP)	Apenas PyTorch	Times PyTorch (NLP, CV)
AIX 360	IBM	8+ algoritmos diferentes; foco em diversidade de explicações	Documentação irregular	Pesquisa, comparação de métodos
Alibi Explain	Seldon	Counterfactuals, anchor explanations, prototype-based	Comunidade menor	Counterfactuals acionáveis em produção
InterpretML	Microsoft Research	EBM (Explainable Boosting Machine) — modelo "glass-box" de alta acurácia	EBM é a estrela; outros métodos são wrappers	Quando você pode escolher um modelo interpretável de origem

⚠ RISCO PRINCIPAL: Sem supervisão humana real, erros da IA escalam sem controle — e a organização não consegue responder a reguladores, auditores ou vítimas.

Human-in-the-Loop (HITL) por risco

Definir quais decisões sempre requerem revisão humana antes de executar.
Critérios: impacto financeiro, direitos fundamentais, reversibilidade.
Threshold claro.

Human-on-the-Loop (HOTL)

Humano monitora o sistema operando autonomamente e pode intervir.
Adequado para decisões de menor impacto com alto volume.

Mecanismo de contestação

Implementar fluxo formal para que afetados possam questionar decisões automatizadas. Exigido pela LGPD Art. 20 e EU AI Act Art. 14.

Registro de responsabilidade (AI Register)

Manter inventário de todos os sistemas de IA com: dono, propósito, dados usados, nível de risco, responsável por revisão e data de última auditoria.

FERRAMENTAS

Label Studio (HITL) · Prodigy (anotação) · Fiddler AI (monitoring) · AI Register templates (NIST)

TRADE-OFF

Supervisão ↔ Escala: mais revisão humana reduz velocidade e aumenta custo. Automatizar sem supervisão aumenta risco. Calibrar pelo risco da decisão.

4 Humanos no Loop (HITL): supervisão e responsabilização

Responsabilização (accountability) exige que pessoas, não algoritmos, sejam, em última instância, responsáveis pelas decisões. HITL é o mecanismo técnico que viabiliza isso.



Durante o TREINAMENTO

Humano modela o que é "bom"

- RLHF (Reinforcement Learning from Human Feedback) — humanos rankeiam saídas, modelo aprende preferência (ChatGPT, Claude, Gemini)
- Constitutional AI (Anthropic) — humanos escrevem princípios; modelo se autoavalia
- Direct Preference Optimization (DPO) — alternativa mais simples ao PPO
- Active learning — humano rotula apenas amostras de maior incerteza
- Red Team rounds — equipe de humanos testa antes do release



Durante a INFERÊNCIA

Humano supervisiona o uso

- HITL síncrono — humano aprova ANTES da ação (pagamento, envio de email, ação irreversível)
- HITL assíncrono — humano revisa amostragem após (auditoria contínua)
- Human-on-the-loop — humano monitora dashboard e intervém se necessário
- Escalation — confiança baixa → roteia para humano
- Override / kill switch — capacidade de parar o sistema

⚠ RISCO PRINCIPAL: Dados pessoais usados indevidamente no treinamento podem ser extraídos via outputs — gerando passivo jurídico permanente (LGPD/GDPR).

Anonimização e pseudonimização

Remover ou mascarar PII antes do uso em treinamento. Ferramentas: Microsoft Presidio, AWS Macie. Atenção: re-identificação é um risco real.

Differential Privacy

Adicionar ruído matemático controlado aos dados ou gradientes durante o treinamento: garante que o modelo não memorize registros individuais.

Federated Learning

Treinar modelos localmente nos dispositivos dos usuários sem enviar dados brutos para o servidor central. Privacidade by design.

Avaliação de impacto de privacidade (DPIA)

Processo formal para identificar e mitigar riscos de privacidade antes do deploy. Obrigatório pela LGPD para processamento de dados sensíveis em larga escala.



FERRAMENTAS

Microsoft Presidio · Google DP Library · OpenDP · PyCap (Privacidade)



TRADE-OFF

Privacidade ↔ Precisão: differential privacy e anonimização reduzem a qualidade dos dados, impactando a performance do modelo.

Princípios (NIST)

- Anonimato
- Confidencialidade
- Controle (consent)
- Minimização de dados
- Limitação de propósito

Direitos do titular (LGPD/GDPR)

- Acesso aos dados
- Correção / retificação
- Eliminação (right to be forgotten)
- Portabilidade
- Revisão humana de decisões automatizadas

Bases legais comuns

- Consentimento explícito
- Legítimo interesse
- Cumprimento de obrigação legal
- Execução de contrato
- Proteção da vida

Retenção em IA: exigências

- Documentação técnica (EU AI Act Art. 11)
- Logs do sistema (Art. 12)
- Sistema de gestão da qualidade (Art. 17)
- Dataset card / data lineage
- Plano de descarte de modelos e dados

Regulações com forte impacto em IA: LGPD (BR · 2018) · GDPR (UE · 2018) · EU AI Act (UE · 2024) · PL 2338/2023 (BR — em tramitação) · Resolução CFM 2.314/22 (saúde)

Conjunto de técnicas que permitem extrair valor de dados sensíveis preservando a privacidade dos titulares — alinhadas a LGPD/GDPR e essenciais para training/inferência de IA com PII.

Anonimização

Remove identificadores diretos e indiretos. Limitação: re-identificação via cross-reference (Sweeney 2002).

Pseudonimização

Substitui identificadores por tokens. Reversível com a chave — distinto de anonimização sob LGPD/GDPR.

Differential Privacy

Adiciona ruído calibrado (ϵ, δ) garantindo que o output não revele indivíduos. Padrão Apple/Google/Census US.

Federated Learning

Modelo viaja até o dado, em vez do dado viajar. Útil em hospitais, dispositivos. Frameworks: Flower, FATE, OpenFL.

Secure Multi-Party Computation (SMPC)

Várias partes computam função conjunta sem revelar entradas. Ex.: scoring entre bancos.

Homomorphic Encryption

Computar sobre dados criptografados sem descriptografar. Microsoft SEAL, IBM HELib. Custo computacional alto.

Confidential Computing (TEE)

Hardware enclave (Intel SGX, AMD SEV, NVIDIA H100 confidential) — dados protegidos em uso.

Dados Sintéticos

Dados gerados artificialmente preservando propriedades estatísticas. Útil em saúde, fraude, classes minoritárias.

Para IA generativa, o problema central é evitar que PII de prompts vá para LLMs externos (OpenAI, Anthropic, Google) — e que respostas memorizem PII do treino. "PII firewall" tornou-se padrão.

Ferramenta	Mantenedor	Pontos fortes	Pontos de atenção	Quando usar
Microsoft Presidio	Microsoft / OSS	Detector + Anonymizer + Image Redactor; pluggable (NER, regex, custom); multi-idioma incluindo PT-BR	Não pega 100% — atacantes criativos passam; tuning de score necessário	Pré-processamento de prompts; sanitização de logs; pipelines de PII
LLM Guard	Protect AI / OSS	Suite de scanners input/output; integrado a langfuse, litellm; 25+ scanners	Performance pode pesar; falsos positivos em texto técnico	Gateway entre app e LLM; CI/CD de prompts
AWS Comprehend PII	AWS	Serviço gerenciado; suporte a vários idiomas; integrado a S3 / Glue	Lock-in AWS; pago por chamada	Stack AWS, batch sobre buckets de dados
Azure AI Language — PII	Azure	Serviço gerenciado; suporte a entidades health (HIPAA)	Lock-in Azure	Stack Microsoft, dados de saúde
Google DLP	Google Cloud	100+ infoTypes; redação automatizada; templates GDPR/HIPAA	Lock-in GCP; preço por volume	Stack GCP, dados em BigQuery / GCS
Lakera Guard	Lakera (comercial)	Foco em LLMs; PII + prompt injection + jailbreak num único API	SaaS pago; latência de rede	Equipes pequenas que querem proteção rápida sem build

⚠ RISCO PRINCIPAL: LLMs e agentes são vetores de ataque novos. Prompt injection, jailbreak e data poisoning podem comprometer sistemas em produção.

Guardrails de input e output

Filtrar inputs suspeitos e validar outputs antes de exibi-los ou usar em outros sistemas. Ferramentas: Guardrails AI, LlamaGuard, NeMo Guardrails.

Red Teaming estruturado

Simular ataques adversariais deliberados antes do deploy: prompt injection, jailbreak, manipulação de contexto. Documentar e corrigir vulnerabilidades.

Sandboxing de agentes

Executar agentes em ambientes isolados com permissões mínimas. Separar o que o agente pode ler, executar e enviar. Princípio do menor privilégio.

Prompt injection defense

Validar separação entre instruções de sistema e inputs de usuário. Usar delimitadores explícitos. Implementar detecção de instruções maliciosas no input.



FERRAMENTAS

Guardrails AI · NeMo Guardrails (NVIDIA) · LlamaGuard (Meta) · Garak (scanner de LLMs)



TRADE-OFF

Segurança ↔ Usabilidade: filtros mais rígidos aumentam falsos positivos — bloqueando uso legítimo e degradando a experiência.

NIST AI 100-2 (2024) categoriza ataques por OBJETIVO do adversário e CAPACIDADE necessária. Em sistemas de IA, segurança vai além da cibersegurança tradicional.

Disponibilidade

Tornar o sistema inutilizável

- Denial of Service (DoS)
- Resource exhaustion
- Sponge examples

Integridade

Forçar erro de decisão

- Evasion (adversarial examples)
- Data poisoning
- Backdoor attacks

Privacidade

Extrair dados ou modelo

- Membership inference
- Model inversion
- Model extraction / stealing

Abuso (GenAI)

Usar o modelo de forma indevida

- Prompt injection (direta/indireta)
- Jailbreak
- Geração de conteúdo nocivo

CIA tradicional + ABUSO específico de IA = base para o threat modeling de modelos e LLMs

6 MITRE ATLAS: táticas e técnicas adversariais conhecidas

ATLAS (Adversarial Threat Landscape for AI Systems) é a base de conhecimento viva de táticas e técnicas observadas no mundo real — análoga ao MITRE ATT&CK, mas para IA.

#	Técnica MITRE ATLAS	O que faz	Mitigações ATLAS
1	Poison Training Data (T0020)	Injeta exemplos/rótulos maliciosos no treino para implantar vulnerabilidade ou viés	Sanitize Training Data (M0007); Validate ML Model (M0008); Maintain Dataset Provenance (M0025)
2	Backdoor ML Model (T0018)	Modelo opera normal, mas responde a um gatilho secreto	Validate ML Model (M0008); Verify ML Artifacts (M0014); Code Signing (M0013)
3	Evade ML Model (T0015)	Pequenas perturbações na entrada enganam a inferência	Model Hardening (M0003); Use Ensemble (M0006); Adversarial Input Detection (M0015)
4	LLM Prompt Injection / Jailbreak (T0051/T0054)	Prompts maliciosos anulam guardrails e geram saídas perigosas	Generative AI Guardrails (M0020); GenAI Guidelines (M0021); Restrict Model Queries (M0004)
5	Model Extraction (T0024.002)	Copia o comportamento do modelo via consultas à API	Passive ML Output Obfuscation (M0002); Restrict Model Queries (M0004); Control Access (M0019)
6	Model Inversion (T0024.001)	Reconstrói dados sensíveis a partir de scores/confianças	Passive ML Output Obfuscation (M0002); AI Telemetry Logging (M0024); Use Ensemble (M0006)
7	Publish Poisoned Models (T0058/T0019)	Distribui modelos modificados ou datasets maliciosos via Hub público	Verify ML Artifacts (M0014); Code Signing (M0013); Model Distribution Methods (M0017)
8	Denial of ML Service (T0022)	Consultas pesadas/abusivas exaurem recursos, derrubando o serviço	Restrict Model Queries (M0004); Use Ensemble (M0006); AI Telemetry Logging (M0024)

Atualização 2025 traz novas categorias para refletir o avanço de RAG, agentes e system prompts. Vector/Embedding e System Prompt Leakage são novas; Excessive Agency foi expandido.

LLM01	Prompt Injection System prompts imutáveis · validação · separação confiável input/instrução	LLM02	Sensitive Info Disclosure Redação automática de PII · differential privacy · log masking
LLM03	Supply Chain SBOM · assinaturas · scan de modelos do Hub · pinning de versões	LLM04	Data & Model Poisoning Proveniência · validação · scanners de anomalia · hold-out testing
LLM05	Improper Output Handling Escape/encoding · sandboxing · revisão humana ou filtros	LLM06	Excessive Agency [!] Princípio do menor privilégio · HITL para ações irreversíveis · guardrails
LLM07	System Prompt Leakage [novo] Não confiar segredos a system prompts · separar config sensível · auditoria	LLM08	Vector & Embedding Weak. [novo] Controle de acesso a vector DB · validação de embeddings · isolamento de tenants
LLM09	Misinformation Citações obrigatórias · LLM-as-judge · RAGAS · disclaimers	LLM10	Unbounded Consumption Rate limiting · timeouts · monitoring de tokens/custo · auto-scaling com cap

Guardrails para IA Generativa: Exemplos de stacks

Arquitetura típica em 3 camadas (latência crescente, especificidade crescente)

Tier 1 · Regex / Keywords <i>Latência <10 ms</i> API key patterns · banned words · obvious injections	Tier 2 · ML Classifiers <i>Latência 20–100 ms</i> Toxicity · PII (NER) · topic classification	Tier 3 · LLM-as-Judge <i>Latência 0.5–8 s</i> Llama Guard · NeMo policy · jailbreak detection
---	--	--

Stack	Tipo	Pontos fortes	Pontos de atenção	Quando usar
NVIDIA NeMo Guardrails	Programmable / Colang DSL	Input/Dialog/Retrieval/Output/Execution rails; integra LangChain; jailbreak detect via NIM	Curva de aprendizado do Colang; latência de múltiplas LLMs em chain	Apps conversacionais com fluxos rígidos
Guardrails AI	Output validation / RAIL spec	20+ validators; estrutura JSON/Pydantic; re-prompt automático	Foco em saída; menos cobertura de input	Saídas estruturadas (JSON, schemas); RAG
Llama Guard 3 / 4	LLM classifier (Meta)	Open-source; 6 categorias unsafe; rápido em GPU; multimodal (Llama Guard 4)	Requer GPU; menos granular que policies customizadas	Filtro de conteúdo binário em GPU
LLM Guard (ProtectAI)	Suite de scanners	25+ scanners input/output; integra Langfuse/LiteLLM	Cada scanner adiciona latência	Gateway entre app e LLM
Azure AI Content Safety / Prompt Shield	Managed (Azure)	Categorias hate/sexual/violence/self-harm; jailbreak detection	Lock-in Azure	Stack Microsoft, compliance enterprise
Lakera Guard	Managed SaaS	PII + Prompt Injection + Jailbreak em uma API; baixa latência	SaaS pago; dados saem do tenant	Quem quer proteção fim-a-fim sem build

Fonte: github.com/NVIDIA-NeMo/Guardrails · guardrailsai.com · llama.meta.com/llama-guard · github.com/protectai/llm-guard



GOVERNANCE &
RESPONSIBLE AI

Ciclo de Vida de Modelos de IA

Os pilares e suas ferramentas práticas

AI Engineering & Multi-Agents · Turma 1AIER



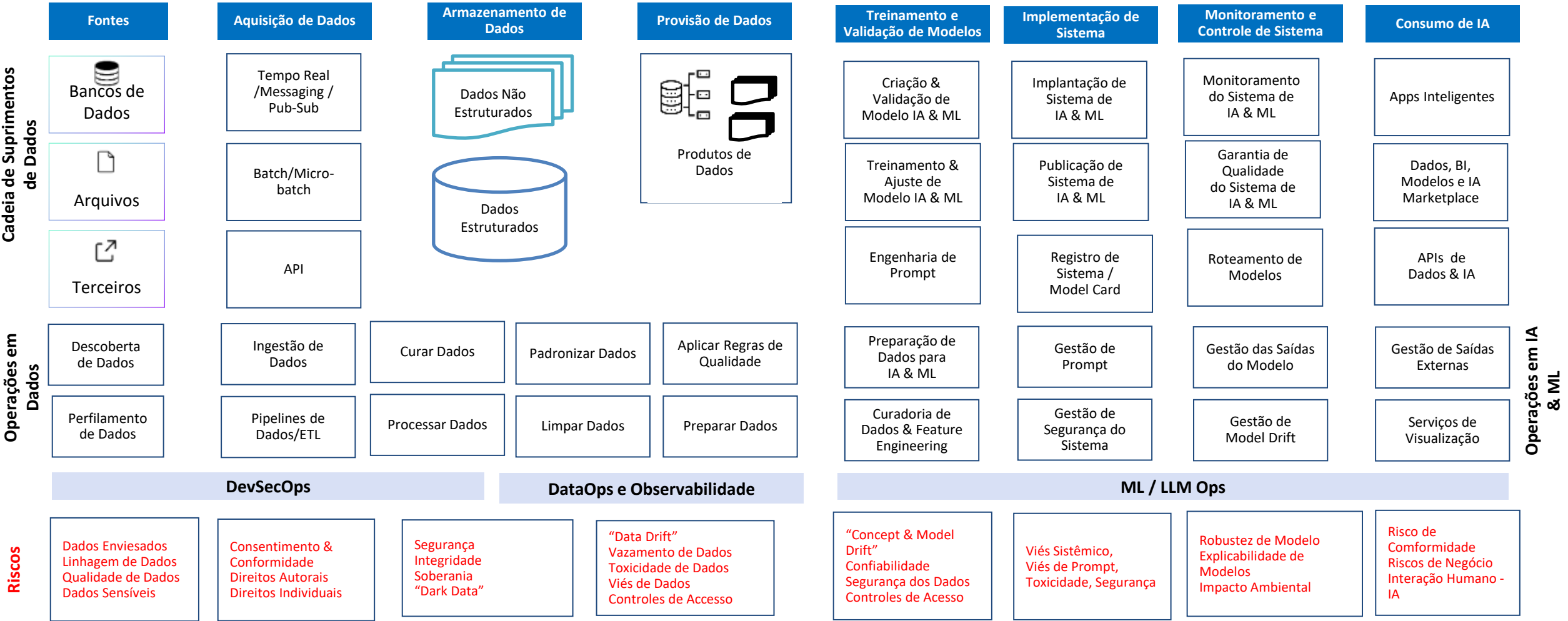
Ciclo de Vida da IA e Monitoramento Contínuo

IA em produção não é estática. Dados mudam, comportamentos dos usuários mudam, o mundo muda. Monitoramento contínuo não é opcional, é parte da mitigação.



Riscos estão na cadeia toda, das fontes ao consumo

Cada estágio tem seu portfólio de riscos · governança e segurança são CONTÍNUAS



Mensagem central: governança da IA depende de governança de dados sólida. Os controles têm de cobrir: fontes, ingestão, armazenamento, provisão, treinamento/validação, implantação, monitoramento e consumo.

Síntese da aula

Os 3 takeaways

01

Mitigação é PORTFÓLIO de controles

Não há "solução de Responsible AI". Cada pilar (Justiça, Robustez, Transparência, HITL, Privacidade, Segurança) tem suas próprias técnicas e ferramentas. Combine pre/in/post-processing e arquiteturas em camadas.

02

Ferramentas são MADURAS, use-as

Fairlearn, AIF360, SHAP, LIME, Captum, Microsoft Presidio, NeMo Guardrails, Llama Guard, Guardrails AI, MITRE ATLAS, OWASP LLM Top 10. Open-source, ativas, com comunidade. AI Engineer responsável é AI Engineer que usa o ferramental.

03

Riscos vivem no CICLO DE VIDA inteiro

Da fonte de dados ao consumo, monitorar é tão importante quanto desenhar. NIST AI RMF, Brasport, Databricks DASF/DAGF — três visões para você se localizar.

PRÓXIMA AULA — Aula 5

Tudo o que vimos hoje continua valendo, mas em Agentic AI os riscos AMPLIFICAM porque agentes EXECUTAM AÇÕES. Excessive Agency, prompt injection com side-effects, ferramentas inseguras, autonomia vs controle. Plus: o projeto final (Quantum Commerce).

Trabalho 2: Estudo de Caso de RAI - Mobley v. Workday, Inc.

Discriminação Algorítmica em IA de RH

CENÁRIO

Derek Mobley, negro, +40 anos, com deficiência, aplicou para mais de 100 vagas via Workday e foi rejeitado automaticamente em todas, sem entrevista, frequentemente de madrugada. Ele alega que o sistema de IA da Workday discrimina por raça, idade e deficiência. Em mai/2025, o caso foi certificado como ação coletiva. Em mar/2026, a Workday sofreu nova derrota parcial. O mérito ainda não foi julgado, decisão esperada em 2026.

1 Análise de Princípios RAI

Identifique cada princípio RAI impactado e justifique com evidência específica do caso.

 30%

2 Classificação de Risco de IA

Mínimo, Limitado, Alto ou Inaceitável? Use a tabela de critérios do enunciado, justifique a escolha e explique as consequências práticas.

 15%

3 Falhas de Governança

Para cada componente da estrutura de governança (Aula 3): identifique a falha na Workday e nas empresas-clientes.

 25%

4 Plano de Mitigação

Para os 3 principais riscos: indique a técnica de mitigação, a ferramenta concreta e o papel responsável.

 20%

5 Declaração do Chief AI Officer

Redijam a declaração do CAIO da Workday após a ação coletiva. Máx. 8 linhas. Reconheça, anuncie ações concretas, seja responsável.

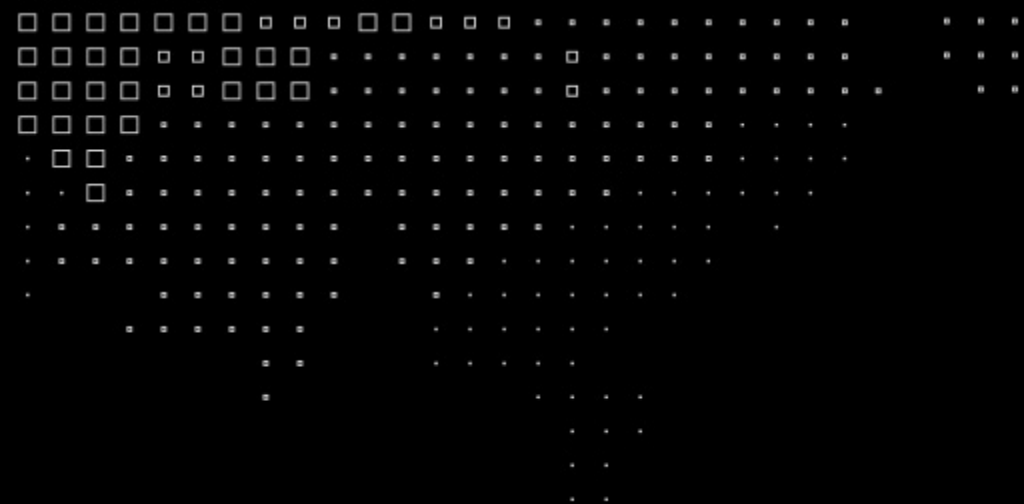
 10%

 Grupos de 4 pessoas

 Enunciado detalhado no documento Word

 Entrega até: 15/05/2026

FINAL DA PARTE 4



MBA⁺

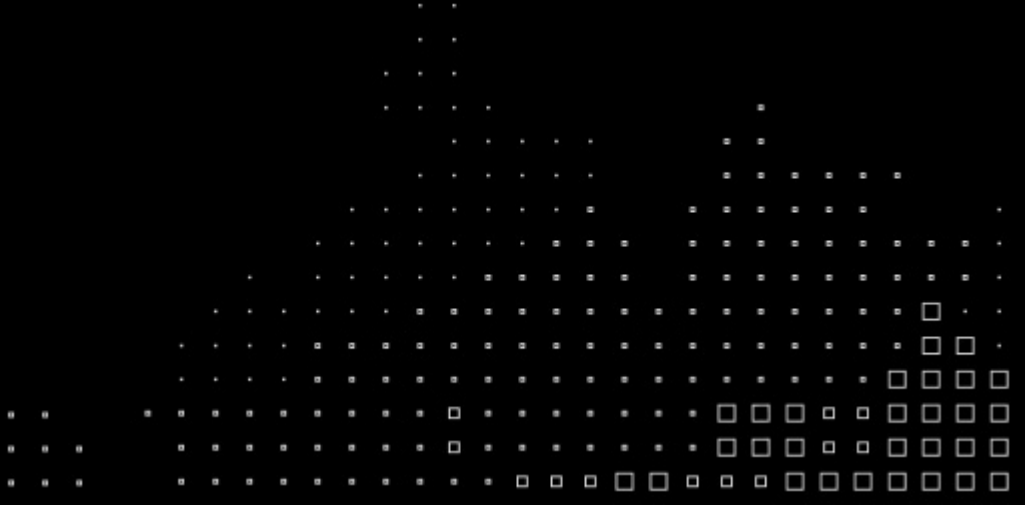
Copyright © **2026** Professores:

- Sergio Alexandre Naime Mantovani

Todos direitos reservados. Reprodução ou divulgação total ou parcial deste documento é expressamente proibida sem o consentimento formal, por escrito, dos Professores (autores).

MBA⁺

**MBA DATA SCIENCE &
ARTIFICIAL INTELLIGENCE**



OBRIGADO

